BÀI THỰC HÀNH 1

Nhận diện bề mặt tấn công bằng Nmap

Học phần: Nhập môn An toàn thông tin (3 TC) • CLO10 • Thời lượng: 2 tiết

Tóm tắt. Bài thực hành giúp người học dựng môi trường ảo hóa (sandbox) an toàn, dùng Nmap để nhận diện cổng/dịch vụ của một hệ thống trong phạm vi được cấp phép, liên hệ với bộ ba CIA và đề xuất biện pháp giảm bề mặt tấn công. Sản phẩm nộp: phiếu kết quả thực hành + tệp `ketqua_bai1.txt`.

1 Phân bổ thời lượng (gợi ý cho người hướng dẫn)

Bảng 1: Gợi ý phân bổ 2 tiết

Thời gian	Hoạt động
Tiết 1 – Dựng môi trường & quét cơ bản	
0–10’	Phổ biến quy tắc an toàn/pháp lý; giới thiệu môi trường ảo hóa và các chế độ mạng; chia nhóm, ghi phạm vi quét được cấp phép.
10–18’	Dựng bề mặt tấn công mẫu (cài Nmap + bật ssh/apache2/vsftpd), ghi IP máy ảo.
18–25’	Bước 1–2: kiểm tra Nmap, (phương án B) phát hiện host trong mạng lab.
25–45’	Bước 3–4: quét cổng cơ bản và nhận diện dịch vụ/phiên bản; bắt đầu điền phiếu.
Tiết 2 – Dò OS, phân tích & giảm bề mặt tấn công	
45–53’	Bước 5: dò hệ điều hành (tham khảo).
53–63’	Bước 6: quét cổng cụ thể và xuất tệp kết quả.
63–75’	Bước 7: phân tích từng cổng theo CIA và đề xuất biện pháp (điền bảng).
75–85’	Bước 8: tắt dịch vụ thừa và quét lại; so sánh trước/sau.
85–92’	Mở rộng (quyền tệp, Have I Been Pwned/Shodan); nộp phiếu, chốt bài.

Bài thực hành phục vụ **CLO10** – *thực hiện được một số hoạt động thực hành an toàn thông tin theo hướng dẫn* (mức Vận dụng). Phạm vi: nhận diện cổng, dịch vụ và đề xuất giảm bề mặt tấn công; chưa yêu cầu đánh giá lỗ hổng chuyên sâu. Sản phẩm nộp là phiếu kết quả thực hành cuối buổi. (Việc khớp chính thức với khung chương trình cần đối chiếu đề cương học phần và ma trận CLO đã phê duyệt.) Trước khi bắt tay vào quét, người học cần hiểu và tự lựa chọn được môi trường thực hành phù hợp – nội dung trình bày ngay dưới đây.

2 Môi trường thực hành ảo hóa (sandbox)

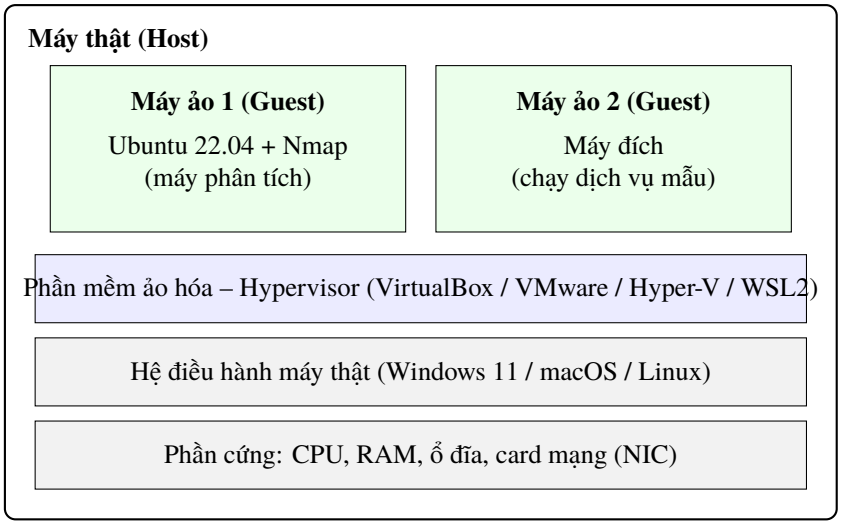
Mọi thao tác thu thập thông tin, quét và thử nghiệm trong học phần đều phải diễn ra trong một *môi trường cô lập* (sandbox), tách khỏi máy tính và mạng thật của người học. Sandbox cho phép thử nghiệm, mắc lỗi và thậm chí làm hỏng hệ thống mà không ảnh hưởng tới máy thật, dữ liệu cá nhân hay mạng của nhà trường. Cách phổ biến và rẻ nhất để tạo sandbox là *ảo hóa*: dùng một phần mềm tạo ra các *máy ảo* (guest) chạy bên trên *máy thật* (host).

Hai khái niệm cần phân biệt ngay từ đầu:

- **Máy thật (Host):** máy tính vật lý của người học cùng hệ điều hành chính (Win-

dows 11, macOS hoặc Linux).

- **Máy ảo (Guest):** một "máy tính trong máy tính" do phần mềm ảo hóa (hypervisor) tạo ra, có CPU, RAM, ổ đĩa và card mạng ảo riêng. Guest có thể bị cô lập hoàn toàn khỏi host.



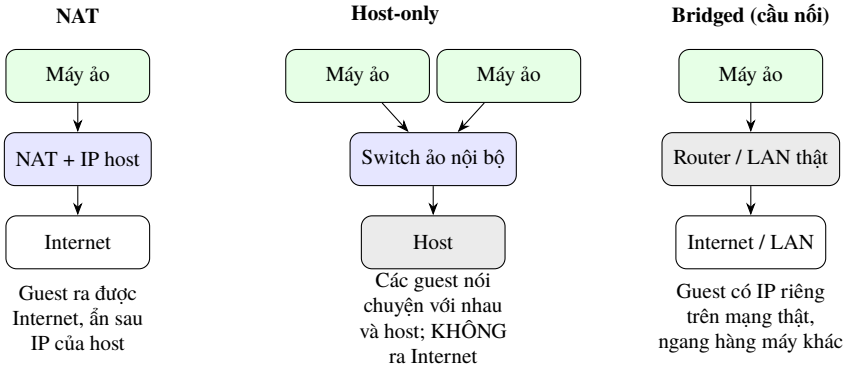
Hình 1: Kiến trúc phân lớp host–guest: phần mềm ảo hóa tạo các máy ảo (guest) dùng chung tài nguyên của máy thật (host) nhưng được cô lập với nhau và với host.

2.1 Các nền tảng ảo hóa phổ biến

Người học có thể chọn một trong các nền tảng dưới đây tùy theo hệ điều hành và cấu hình máy. Trong học phần, **VirtualBox** được khuyến nghị làm lựa chọn mặc định vì miễn phí, chạy trên mọi phiên bản Windows và dễ tạo mạng lab nội bộ.

2.2 Kiến trúc host–guest và các chế độ mạng

Điều quyết định mức độ an toàn của sandbox chính là *chế độ mạng* gán cho card mạng ảo của guest. Ba chế độ thông dụng được minh họa ở Hình 2.



Hình 2: Ba chế độ mạng của máy ảo. **NAT**: guest ra Internet qua IP của host. **Host-only**: mạng lab cô lập giữa các guest và host, không ra Internet – phù hợp nhất cho bài thực hành này. **Bridged**: guest nối thẳng vào mạng thật như một máy độc lập.

Bảng 2: So sánh nhanh các nền tảng ảo hóa

Nền tảng	Đặc điểm	Phù hợp khi
VirtualBox	Miễn phí, mã nguồn mở; chạy máy ảo đầy đủ (Linux, Windows); hỗ trợ NAT, Host-only, Bridged, snapshot.	Lựa chọn mặc định của học phần; dựng phòng lab nhiều máy, máy đích, máy Kali.
VMware Workstation Player	Miễn phí cho mục đích học tập; hiệu năng và tương thích tốt; đủ các chế độ mạng và snapshot.	Thay thế VirtualBox khi cần hiệu năng cao hơn.
Hyper-V	Tích hợp sẵn trong Windows 10/11 bản Pro/Education (không có ở bản Home); máy ảo đầy đủ; mạng qua Virtual Switch (Internal / Private / External).	Máy đã có Windows Pro và không cần chạy song song VirtualBox/VMware.
WSL2	Chạy nhân Linux nhẹ tích hợp trong Windows; khởi động nhanh, tích hợp tốt với công cụ lập trình; không phải máy ảo đầy đủ.	Biến máy cá nhân thành môi trường Ubuntu để lập trình và triển khai dự án (xem mục dưới).

- **NAT:** guest truy cập Internet (để cài gói, cập nhật) nhưng ẩn sau IP của host; các máy khác trong mạng thật không thấy guest. Dùng khi cần tải phần mềm về máy ảo.
- **Host-only (hoặc Internal Network):** theo cấu hình mặc định, tạo một mạng lab *cô lập* chỉ gồm host và các guest, không ra được Internet. Đây là chế độ **khuyến nghị cho bài thực hành**: máy phân tích và máy đích thấy nhau để quét, nhưng không ảnh hưởng ra ngoài. Lưu ý: nếu bật chia sẻ kết nối hoặc định tuyến trên host thì mức cô lập có thể thay đổi, nên cần kiểm tra cấu hình thực tế.
- **Bridged (cầu nối):** guest xin một địa chỉ IP trực tiếp từ router và trở thành một máy ngang hàng trên mạng thật. *Thuận tiện nhưng rủi ro*: thao tác quét/thử nghiệm có thể chạm tới các thiết bị thật trong mạng, do đó không dùng cho bài thực hành quét cổng.

Mẹo thiết lập thường dùng: gán cho máy ảo *hai* card mạng – một card NAT để cài đặt/cập nhật gói, một card Host-only để tạo mạng lab; khi thực hành quét thì chỉ làm việc trên dải Host-only. Trước khi quét, kiểm tra địa chỉ và card đang bật bằng `ip a` và xác định rõ đang quét trên dải mạng nào, tránh vô tình quét ra ngoài phạm vi lab.

2.3 Nên dùng WSL2 hay Hyper-V trên máy cá nhân?

Nhiều người học muốn biến ngay máy cá nhân thành "máy Linux" để triển khai dự án hoặc chạy công cụ bảo mật mà không dựng máy ảo đầy đủ. Hai lựa chọn tích hợp sẵn trong Windows là WSL2 và Hyper-V; mỗi lựa chọn phù hợp một mục tiêu khác nhau.

WSL2 – để lập trình và triển khai dự án: phù hợp. WSL2 chạy một nhân Linux thật, nhẹ và khởi động nhanh, tích hợp tốt với Windows và các trình soạn mã. Đây là lựa chọn rất tốt để biến máy cá nhân thành môi trường Ubuntu nhằm lập trình và triển khai dự án: cài và chạy Python, PHP, Node.js, cơ sở dữ liệu PostgreSQL/MySQL, máy chủ

web, rồi làm việc ngay từ Windows. Nmap cũng cài và chạy được trên WSL2 cho các thao tác quét ở mức học tập.

WSL2 – để làm phòng lab tấn công/Kali: hạn chế. WSL2 không phải máy ảo đầy đủ nên có một số giới hạn khi dùng làm máy tấn công hoặc máy đích:

- Mạng của WSL2 mặc định đi qua một lớp NAT ảo; không có Bridged hay chế độ "nghe lén" (promiscuous) đúng nghĩa như máy ảo đầy đủ (chế độ mirrored trên Windows 11 mới cải thiện phần nào). Vì vậy việc dựng nhiều máy trong một mạng lab cô lập, bắt gói ARP hay dò thiết bị trên dải mạng bị hạn chế.
- Một số công cụ cần quyền gói thô (raw socket), giao diện đồ họa hoặc truy cập trực tiếp card Wi-Fi hoạt động không đầy đủ.
- WSL2 *không* cung cấp snapshot (ảnh chụp khôi phục) như máy ảo – tính năng rất cần khi thử nghiệm phá hoại.
- Có bản "Kali trên WSL" nhưng thiên về tiện lợi dòng lệnh, không thích hợp làm *máy đích cô lập* để tấn công thử.

Hyper-V – hypervisor đầy đủ của Windows. Hyper-V (chỉ có trên Windows bản Pro/Education, không có ở bản Home) chạy máy ảo đầy đủ cho cả Ubuntu lẫn Kali, hỗ trợ Virtual Switch kiểu Private/Internal (tương đương Host-only) và External (tương đương Bridged), phù hợp dựng phòng lab. Lưu ý: bật Hyper-V có thể ảnh hưởng hiệu năng khi chạy song song VirtualBox/VMware (cả WSL2 cũng dùng nền Hyper-V); nếu máy là bản Home thì không có Hyper-V và nên dùng VirtualBox hoặc VMware Player.

Bảng 3: Chọn môi trường theo mục tiêu

Mục tiêu	Khuyến nghị
Học Nmap ở Bài 1 (quét cổng, máy đích đơn giản)	VirtualBox + 1 máy ảo Ubuntu 22.04, card Host-only, có snapshot.
Biến máy cá nhân thành môi trường Ubuntu để lập trình, triển khai dự án (Python, PHP, WordPress, PostgreSQL, MySQL)	WSL2 với Ubuntu – nhẹ, nhanh, tích hợp Windows.
Dựng phòng lab nhiều máy: Kali tấn công + máy đích + mạng cô lập, cần snapshot	Máy ảo đầy đủ: VirtualBox / VMware / Hyper-V với mạng Host-only.
Phân tích mã độc	Máy ảo đầy đủ, cô lập mạng tuyệt đối (xem lưu ý dưới); không dùng WSL2, không dùng Bridged.

2.4 Môi trường sandbox cho phân tích mã độc khác gì?

Sandbox dùng để quét cổng (bài này) chỉ cần cô lập ở mức Host-only. Khi chuyển sang các nội dung về *mã độc máy tính* ở các bài/học phần sau, yêu cầu cô lập phải chặt chẽ hơn nhiều vì mẫu phân tích có thể tự lây lan, phá hủy dữ liệu hoặc gọi về máy chủ điều khiển của kẻ tấn công.

Lưu ý an toàn khi phân tích mã độc. So với sandbox quét cổng, môi trường phân tích mã độc cần bổ sung:

- **Cô lập mạng tuyệt đối:** đặt máy ảo ở Host-only hoặc ngắt mạng hoàn toàn; tuyệt đối không dùng Bridged. Khi cần quan sát hành vi mạng, dùng dịch vụ *mạng giả lập* (ví dụ INetSim) để giả DNS/HTTP thay vì cho mẫu nối ra Internet thật.
- **Snapshot trước, khôi phục sau:** chụp ảnh máy ảo ở trạng thái sạch; sau mỗi lần chạy mẫu thì khôi phục về ảnh sạch (revert) để xóa mọi dấu vết lây nhiễm.
- **Cắt mọi cầu nối với host:** tắt thư mục chia sẻ, bộ nhớ dùng chung (clipboard), kéo-thả tệp và các "tiện ích máy khách" (guest additions) không cần thiết – đây là đường mã độc có thể thoát ra máy thật.
- **Máy ảo chuyên dụng:** dùng máy ảo riêng cho phân tích (ví dụ các bản dựng sẵn như REMnux cho Linux hay môi trường phân tích trên Windows), không dùng chung với máy cá nhân.
- **Tuyệt đối không chạy mẫu trên máy thật** hay trong WSL2 (WSL2 dùng chung nhân và hệ tệp với Windows).

3 Làm việc với máy ảo qua SSH từ máy host

Sau khi cài xong máy ảo, nên bật SSH để điều khiển máy ảo bằng terminal của máy thật (tiện soạn lệnh, sao chép, mở nhiều phiên) thay vì gõ trực tiếp trong cửa sổ Hyper-V.

Trên máy ảo – cài và bật dịch vụ SSH, lấy IP:

```
sudo apt update
sudo apt install -y openssh-server
sudo systemctl enable --now ssh
sudo systemctl status ssh --no-pager     # "active (running)" la OK
hostname -I                              # ghi IP, vd 172.x.x.x
sudo ufw allow 22/tcp 2>/dev/null; sudo ufw status   # neu co bat tuong lua
```

Từ máy host (CMD hoặc PowerShell trên Windows):

```
ssh <user_ubuntu>@<IP_may_ao>
```

Lần đầu gõ `yes` rồi nhập mật khẩu user Ubuntu; đăng nhập được là đã điều khiển máy ảo qua terminal của máy host.

(Tùy chọn) Đăng nhập bằng khóa, khỏi gõ mật khẩu. Trên máy host tạo khóa rồi in khóa công khai; cú pháp biến môi trường khác nhau giữa CMD và PowerShell.

Trên CMD:

```
ssh-keygen -t ed25519 -f %USERPROFILE%\.ssh\id_vm   REM nhan Enter 2 lan de trong
↪  passphrase
type %USERPROFILE%\.ssh\id_vm.pub
```

Trên PowerShell:

```
ssh-keygen -t ed25519 -f $env:USERPROFILE\.ssh\id_vm
type $env:USERPROFILE\.ssh\id_vm.pub
```

Trên máy ảo, thêm khóa công khai đó vào danh sách được phép:

```
mkdir -p ~/.ssh && echo "<dan_noi_dung_id_vm.pub>" >> ~/.ssh/authorized_keys
chmod 700 ~/.ssh && chmod 600 ~/.ssh/authorized_keys
```

Sau đó từ host đăng nhập thẳng bằng khóa (dùng đúng cú pháp biến theo shell):

```
# CMD:        ssh -i %USERPROFILE%\.ssh\id_vm <user>@<IP>
# PowerShell: ssh -i $env:USERPROFILE\.ssh\id_vm <user>@<IP>
```

Lưu ý. Chế độ Default Switch (NAT) đổi IP sau mỗi lần khởi động máy ảo – mỗi buổi chạy lại `hostname -I` để lấy IP mới. Muốn IP cố định thì dùng switch Internal và đặt IP tĩnh cho máy ảo.

4 Mục tiêu

- Sử dụng được Nmap để liệt kê host, cổng và dịch vụ đang mở của một hệ thống trong phạm vi lab.
- Giải thích được vì sao mỗi cổng/dịch vụ mở là một điểm trên bề mặt tấn công.
- Liên hệ kết quả quét với các thuộc tính CIA và đề xuất biện pháp giảm bề mặt tấn công.

5 Quy tắc an toàn và pháp lý

Bắt buộc đọc trước khi thực hành. Quét cổng là hành vi thu thập thông tin về hệ thống. Theo Luật An toàn thông tin mạng 2015 và Luật An ninh mạng, việc thu thập thông tin, dò quét hệ thống thông tin của tổ chức, cá nhân khác khi chưa được phép là hành vi bị nghiêm cấm. Do đó, trong học phần này:

- Chỉ quét các mục tiêu: (1) chính máy ảo của mình (localhost / 127.0.0.1); (2) máy ảo khác trong mạng nội bộ của lab (host-only hoặc NAT nội bộ); (3) máy đích do người hướng dẫn cung cấp và cấp phép rõ ràng.
- Không quét bất kỳ hệ thống nào trên Internet, kể cả website của trường, nhà cung cấp dịch vụ hoặc máy của bạn bè, khi chưa có sự cho phép rõ ràng của chủ sở hữu.
- Không dùng các tùy chọn quét gây tải cao hoặc can thiệp vào dịch vụ ngoài phạm vi hướng dẫn.
- Mọi kết quả thu được chỉ dùng cho mục đích học tập và ghi trong phiếu thực hành.

Bảng 4: Yêu cầu môi trường thực hành

Thành phần	Yêu cầu
Máy chủ (host)	Windows 11, RAM $\geq$ 8 GB, ổ trống $\geq$ 40 GB, đã cài VirtualBox hoặc VMware Workstation Player.
Máy ảo (VM)	Ubuntu 22.04 LTS, 2–3 GB RAM; card mạng thứ hai đặt chế độ Host-only (hoặc Internal Network) để tạo mạng lab nội bộ.
Công cụ	Nmap (cài bằng `sudo apt install nmap`).
Mục tiêu quét	Phương án A: chính máy ảo (127.0.0.1) sau khi bật vài dịch vụ mẫu. Phương án B: máy ảo mục tiêu do người hướng dẫn cung cấp, kết nối cùng mạng Host-only.

6 Chuẩn bị nhanh môi trường lab

Trước khi thực hành, người hướng dẫn nhắc lại (khoảng 10 phút): địa chỉ IP và dải mạng; cổng dịch vụ TCP/UDP và một số cổng thông dụng (22 SSH, 80 HTTP, 443 HTTPS, 21 FTP, 3306 MySQL); khái niệm dịch vụ "lắng nghe" trên cổng; người dùng và quyền truy cập tệp trên Linux.

Nếu dùng phương án A, cài Nmap và dựng bề mặt tấn công mẫu bằng cách bật một vài dịch vụ trên chính máy ảo của mình (bỏ qua nếu dùng phương án B). Toàn bộ khối lệnh dưới đây có thể sao chép và dán trực tiếp vào terminal của máy ảo Ubuntu:

```
sudo apt update
sudo apt install -y nmap openssh-server apache2 vsftpd
sudo systemctl start ssh apache2 vsftpd
ip a            # ghi lai dia chi IP cua may ao trong mang lab
```

Xác nhận dịch vụ đã chạy và đang lắng nghe *trước khi quét*. Nếu một dịch vụ không `active` hoặc cổng không xuất hiện thì kiểm tra lại việc cài/cấu hình dịch vụ đó – đây chính là lý do một cổng có hay không hiện khi quét:

```
systemctl is-active ssh apache2 vsftpd     # moi dong tra ve "active"
sudo ss -lntup                             # liet ke cong dang lang nghe + tien trinh
```

7 Các bước thực hiện

Các lệnh dưới đây được viết để người học sao chép và dán trực tiếp; thay `127.0.0.1` bằng IP máy đích khi dùng phương án B.

Bước 1 – Kiểm tra công cụ và xác định phạm vi quét. Ghi vào phiếu địa chỉ IP/dải mạng được phép quét (do người hướng dẫn thông báo).

```
nmap --version
```

Bước 2 – Phát hiện host trong mạng lab (chỉ khi dùng phương án B). Tùy chọn `-sn` chỉ kiểm tra host nào đang hoạt động, không quét cổng.

```
nmap -sn 192.168.56.0/24      # thay bang dai mang Host-only thuc te
```

Bước 3 – Quét cổng cơ bản. Mặc định Nmap quét 1000 cổng TCP phổ biến nhất. Quan sát các cột PORT, STATE, SERVICE; trạng thái `open` nghĩa là có ứng dụng đang lắng nghe trên cổng đó.

```
nmap 127.0.0.1                # hoac: nmap <IP may dich>
```

Bước 4 – Nhận diện dịch vụ và phiên bản. Tùy chọn `-sV` gửi gói thăm dò để xác định tên và phiên bản phần mềm (ví dụ OpenSSH 8.9, Apache httpd 2.4.52). Thông tin phiên bản là dữ liệu đầu vào để tra cứu lỗ hổng đã biết (CVE) ở Bài 4; trong bài này chỉ cần ghi nhận.

```
nmap -sV 127.0.0.1
```

Bước 5 – (Tùy chọn) Dò hệ điều hành. Tùy chọn `-O` đoán hệ điều hành của máy đích dựa trên đặc điểm gói tin trả lời; kết quả chỉ mang tính tham khảo và cho thấy ngay cả loại hệ điều hành cũng là thông tin kẻ tấn công có thể thu thập.

```
sudo nmap -O 127.0.0.1
```

Bước 6 – Quét một số cổng cụ thể và xuất kết quả. Tùy chọn `-p` chỉ định danh sách cổng; `-oN` lưu kết quả ra tệp văn bản để đính kèm phiếu thực hành.

```
nmap -p 21,22,80,443,3306 -sV 127.0.0.1 -oN ketqua_bai1.txt
```

Bước 7 – Ghi nhận và phân tích kết quả. Điền bảng ở mục phiếu thực hành. Với mỗi cổng mở, trả lời: dịch vụ này có cần thiết không? Nếu bị khai thác thì thuộc tính CIA nào bị ảnh hưởng? Biện pháp giảm bề mặt tấn công là gì? Bài này chưa yêu cầu tra cứu hay đánh giá lỗ hổng cụ thể của từng phiên bản dịch vụ – nội dung đó thuộc Bài 4. **Lưu ý:** một cổng mở chỉ cho thấy một điểm *có thể* bị tấn công, không có nghĩa hệ thống đã bị khai thác hay một thuộc tính CIA chắc chắn bị ảnh hưởng; khi liên hệ CIA, hãy nêu rõ *điều kiện/giả định* (ví dụ: nếu dịch vụ truyền dữ liệu nhạy cảm mà không mã hóa thì tính bí mật bị đe dọa).

Bước 8 – Giảm bề mặt tấn công và quét lại. So sánh hai kết quả trước và sau khi tắt dịch vụ không cần thiết: số cổng mở quan sát được giảm đi – đây là một *chỉ dấu* cho thấy bề mặt tấn công thu hẹp, nhưng chưa phải thước đo đầy đủ (một dịch vụ có thể dùng nhiều cổng, lắng nghe trên nhiều địa chỉ giao diện, hoặc vẫn còn lỗ hổng qua ứng dụng khác).

```
sudo systemctl stop vsftpd && sudo systemctl disable vsftpd
nmap -sV 127.0.0.1
```

Tóm tắt lệnh (copy-paste nhanh). Toàn bộ quy trình quét cho phương án A gói gọn trong khối sau:

```
nmap --version                                              # Buoc 1
nmap 127.0.0.1                                              # Buoc 3
nmap -sV 127.0.0.1                                          # Buoc 4
sudo nmap -O 127.0.0.1                                      # Buoc 5 (tuy chon)
nmap -p 21,22,80,443,3306 -sV 127.0.0.1 -oN ketqua_bai1.txt   # Buoc 6
sudo systemctl stop vsftpd && sudo systemctl disable vsftpd   # Buoc 8
nmap -sV 127.0.0.1                                          # Buoc 8: quet lai
```

8 Phiếu ghi kết quả thực hành (mẫu)

Họ tên: ..... Lớp: ..... Mục tiêu quét (IP): ..... Được cấp phép bởi: .....

Bảng 5: Mẫu phiếu ghi kết quả quét

Cổng	Trạng thái	Dịch vụ / phiên bản	Cần thiết?	CIA bị đe dọa nếu bị khai thác	Biện pháp đề xuất
21	open	vsftpd 3.0.5	Không	C (mật khẩu truyền rõ), I	Ưu tiên tắt FTP; nếu cần dùng SFTP (qua SSH)
22	open	OpenSSH 8.9	Có	C, I nếu mật khẩu yếu	Dùng khóa SSH, tắt đăng nhập root
80	open	Apache 2.4.52	Có	A (DoS), I (deface)	Chuyển sang HTTPS, cập nhật bản vá
…	…	…	…	…	…

Kết thúc phiếu bằng nhận xét 3–5 câu: dịch vụ nào đáng lo ngại nhất và vì sao; số cổng mở trước và sau khi giảm bề mặt tấn công; bài học rút ra về nguyên tắc đặc quyền tối thiểu.

9 Ví dụ kết quả tham khảo (có nhận xét)

Bảng dưới là kết quả *quét mặc định* (`nmap -sV`, khoảng 1000 cổng phổ biến) trên `127.0.0.1` để người học đối chiếu cách điền phiếu. Lưu ý: lệnh quét theo danh sách cổng ở Bước 6 (`-p 21,22,80,443,3306`) chỉ kiểm tra 5 cổng nên *không* bao gồm cổng 631; cổng 631 chỉ xuất hiện ở lần quét mặc định (Bước 3–4).

Một số nhận xét rút ra:

- Trước khi giảm bề mặt có 4 cổng mở (21, 22, 80, 631); sau khi tắt `vsftpd` còn 3 cổng – bề mặt tấn công thu hẹp đúng kỳ vọng.
- Dịch vụ `631/CUPS` (in ấn) thường bật mặc định trên Ubuntu: đây là ví dụ điển hình của *dịch vụ thừa* làm rộng bề mặt tấn công, minh họa trực tiếp nguyên tắc đặc quyền tối thiểu.
- `nmap -O` có thể không khớp hệ điều hành khi quét localhost (Network Distance = 0 hop); kết quả dò hệ điều hành chính xác hơn khi quét máy đích qua mạng lab.

Bảng 6: Kết quả quét mẫu và phân tích

Cổng	Trạng thái	Dịch vụ / phiên bản	Cần thiết?	CIA bị đe dọa	Biện pháp
21	open	vsftpd 3.0.5	Không	C (truyền rõ mật khẩu), I	Ưu tiên tắt FTP; nếu cần, SFTP (qua SSH)
22	open	OpenSSH 9.6p1	Có	C, I nếu mật khẩu yếu	Khóa SSH, tắt đăng nhập root
80	open	Apache 2.4.58	Có	A (DoS), I (deface)	Chuyển HTTPS, cập nhật bản vá
631	open	CUPS 2.4 (IPP)	Không	C (lộ thông tin in ấn), A	Chỉ nghe localhost hoặc tắt
443	closed	https	–	–	Mở khi bật HTTPS
3306	closed	mysql	–	–	Giữ đóng / bind 127.0.0.1

Bằng chứng trước/sau khi giảm bề mặt. Sau khi chạy `sudo systemctl stop vsftpd` rồi quét lại, cổng 21 biến mất; còn 3 cổng mở: 22 (ssh), 80 (http), 631 (ipp). Hai lần quét trước/sau là minh chứng cần đính kèm phiếu.

FTP và SFTP không giống nhau. FTP (dịch vụ `vsftpd`, cổng 21) truyền thông tin xác thực và dữ liệu ở dạng rõ; còn SFTP là giao thức truyền tệp chạy *qua SSH* (cổng 22), không phải "FTP thêm chữ S". Vì vậy ưu tiên *tắt* dịch vụ FTP nếu không cần; chỉ dùng SFTP khi thực sự cần truyền tệp.

9.1 Thảo luận: bề mặt tấn công của một thiết bị mạng (ví dụ ẩn danh)

Thiết bị mạng (bộ định tuyến, camera IP, thiết bị IoT) cũng có bề mặt tấn công, thường rộng hơn ta tưởng. Bảng dưới là ví dụ *minh họa đã ẩn danh* (địa chỉ và dịch vụ chỉ mang tính tượng trưng) để thảo luận.

Chỉ để thảo luận. Không quét bộ định tuyến, thiết bị của nhà cung cấp dịch vụ hay bất kỳ thiết bị nào ngoài phạm vi lab được cấp phép – đây là hành vi bị pháp luật nghiêm cấm.

Điểm rút ra: ngoài `open` và `closed`, còn trạng thái `filtered` nghĩa là cổng bị tường lửa lọc nên Nmap không xác định được. Thiết bị mạng mặc định thường bật nhiều dịch vụ quản trị (web, UPnP, Telnet) – cần tắt bớt và giới hạn truy cập để thu hẹp bề mặt tấn công.

10 Mở rộng và thảo luận

- Quyền tệp trên Linux cũng là một bề mặt tấn công: chạy `ls -l /etc/passwd /etc/shadow` và giải thích vì sao hai tệp có quyền khác nhau (sẽ học kỹ ở Bài 4 – hardening).
- Bề mặt tấn công ở quy mô Internet: người hướng dẫn minh họa cách tra cứu email đã rò rỉ tại Have I Been Pwned và cách Shodan liệt kê thiết bị lộ trên Internet. Người học chỉ tra cứu địa chỉ email của chính mình; không dùng Shodan để tìm

Bảng 7: Ví dụ minh họa (ẩn danh) – bề mặt tấn công của một bộ định tuyến gia đình

Cổng	Trạng thái	Dịch vụ	Nhận định rủi ro
22	filtered	ssh	Bị tường lửa lọc (không phản hồi) – an toàn hơn trạng thái open.
23	filtered	telnet	Telnet truyền dữ liệu dạng rõ; nên tắt hẳn thay vì chỉ lọc.
53	open	domain (DNS)	Dịch vụ phân giải tên; nguy hiểm nếu lộ ra Internet (bị lạm dụng).
80/443	open	http/https (trang quản trị)	Chỉ nên cho truy cập quản trị từ mạng nội bộ, đặt mật khẩu mạnh.
1900	open	upnp	UPnP tự mở cổng theo yêu cầu ứng dụng – rủi ro mở cổng ngoài ý muốn.

và truy cập thiết bị của người khác.

- Câu hỏi: nếu một máy chủ chỉ mở cổng 443 nhưng chạy phần mềm web đã lỗi thời, bề mặt tấn công có thực sự nhỏ không?

11 Sản phẩm nộp và đánh giá

Bảng 8: Tiêu chí đánh giá sản phẩm thực hành

Tiêu chí	Điểm	Yêu cầu
Thực hiện đúng quy tắc phạm vi quét	2	Chỉ quét mục tiêu được cấp phép, ghi rõ nguồn cấp phép.
Kết quả quét đầy đủ	3	Có kết quả `nmap -sV` và bảng cổng/dịch vụ điền đủ các cột.
Liên hệ CIA và đề xuất giảm bề mặt tấn công	3	Mỗi cổng mở có nhận định hợp lý về thuộc tính CIA và biện pháp.
So sánh trước/sau khi giảm bề mặt tấn công	2	Có hai kết quả quét và nhận xét sự khác biệt.